Relatório da execução oficial

TCC 2 · Correção automática de vulnerabilidades com LLM no OWASP Juice Shop

Execução de 06/11/2026 · 78 casos · 3 modelos · 4 estratégias de prompt · Caio Lamego e Matheus Brant (UnB/FCTE)

Resumo. A campanha completa rodou sem erro nos três modelos: 834 tentativas, 834 chamadas reais à LLM e US$ 0,89 no total. Nenhuma resposta da LLM nem resultado de teste ou do Semgrep foi reaproveitado de execução anterior. Os números abaixo usam a definição oficial de F (*critério*), em que os testes que exigem a própria vulnerabilidade não reprovam a correção.

Modelo	Casos corrigidos	CR	TRV	RRIS	Custo	Horário
GPT-6 Luna	49/78	62,8%	22,2%	60,3%	US$ 0,14	07:55–09:57
GPT-5.6 Luna	51/78	65,4%	22,9%	70,5%	US$ 0,31	09:57–12:10
GPT-4.1 mini	38/78	48,7%	15,8%	48,7%	US$ 0,43	12:10–14:20

CR: casos com pelo menos uma correção aceita, sobre 78. TRV: tentativas aceitas sobre as tentativas feitas até o primeiro aceite. RRIS: redução dos alertas do Semgrep com as correções aceitas aplicadas juntas.

O que mais importa

- **GPT-5.6 Luna e GPT-6 Luna ficaram empatados** (p = 0,79). Os dois corrigiram mais casos que o GPT-4.1 mini; com a correção para três comparações, só a diferença entre GPT-5.6 Luna e GPT-4.1 mini continua abaixo de 0,05.
- **O aceite depende muito do conjunto D.** Se todos os testes contassem, os casos aceitos seriam 23 (GPT-6 Luna), 22 (GPT-5.6 Luna), 17 (GPT-4.1 mini). Mais da metade das correções aceitas fez falhar algum teste que exige a vulnerabilidade (TCD, seção 10).
- **Um alerta corrigido ainda não é uma vulnerabilidade corrigida.** R=1 só diz que o Semgrep parou de apontar. Dos 78 casos, 21 são falsos positivos da triagem, e a inspeção manual das correções aceitas ainda não foi feita.
- **A RRIS mede a redução no Semgrep, não a validação funcional.** Nenhum dos três conjuntos de correções passou em todos os testes; as três falhas foram explicadas (seção 8).
- **58 casos** foram corrigidos por pelo menos um modelo, **32** pelos três e **20** por nenhum.

Os resultados estão no branch `feat/reorganizacao-codigo`, já enviados ao GitHub. O que ainda falta decidir ou fazer está na seção 14.

1. O que foi executado

Cada caso é um alerta do Semgrep em um ponto do código. Para cada caso e modelo, o pipeline monta o prompt, pede a correção, aplica o patch numa cópia isolada do Juice Shop, roda o Semgrep e os testes, e decide se a correção vale.

Item	Valor
Alvo	OWASP Juice Shop v20.1.1, commit f915bddd8279
Catálogo	78 casos (alertas do Semgrep elegíveis), cada um com uma linha e uma regra. Triagem manual: 55 confirmados, 21 falsos positivos, 2 inconclusivos
SAST	Semgrep 1.177.0, sem login, perfil ampliado_piloto_v1 (regras do registro e regras próprias)
Comparador	ocorrencias_contexto_v3 (decide pela contagem quando o alerta muda de linha; seção 11)
Validação	política relacionada_v2: testes dos grupos ligados ao arquivo alterado; revisão de cobertura v8, mapa v9, conjunto D v3
Baseline	outputs/cobertura_funcional/IMAGEM_81FE_D3_20261106/ (52 grupos comparáveis)
Ambiente	Docker, imagem sha256:81fe6403f07a..., TZ=UTC, NODE_ENV=test, 4 worktrees em paralelo (K=4)
RAG	Base 2.1 com 14 documentos; documento inteiro escolhido pela CWE do alerta (primeira CWE, senão categoria)
Cache	Cache de respostas da LLM desligado e cache de validação desligado (seção 9)
Código	Commit 10134d9 (validação e comparador), baseline cdb9bab, resultados fe027f6, 8c76129 e 23437ca, RRIS e3b8ae4 e 062a203

Modelos. Os três foram chamados pela API da OpenAI, com temperatura 0, sem raciocínio estendido nos modelos Luna e com semente 42 no GPT-4.1 mini. O identificador devolvido pela API está registrado em cada tentativa.

Modelo	ID devolvido	Parâmetros	Preço por milhão de tokens (entrada / em cache / saída, US$)	Execução
GPT-6 Luna	gpt-6-luna	max_completion_tokens=4096, reasoning_effort=none, temperature=0	0,10 / 0,01 / 0,50	AMP_REAL_20261106T105533Z_aa697342
GPT-5.6 Luna	gpt-5.6-luna	max_completion_tokens=4096, reasoning_effort=none, temperature=0	0,20 / 0,02 / 1,20	AMP_REAL_20261106T125801Z_0eb68fe4
GPT-4.1 mini	gpt-4.1-mini-2025-04-14	max_completion_tokens=4096, seed=42, temperature=0	0,40 / 0,10 / 1,60	AMP_REAL_20261106T151004Z_f49ac0d2

Estratégias de prompt. P1 traz só o alerta e o código. P2 acrescenta um roteiro de raciocínio guiado. P3 acrescenta o documento da base de conhecimento (RAG). P4 junta o documento e o roteiro.

Cadeia. Cada caso começa em P1 e segue para P2, P3 e P4 até uma correção passar em *todos* os testes (aceite estrito). Uma tentativa aceita pelo critério oficial, mas não no estrito, deixa a cadeia continuar; as tentativas feitas depois do primeiro aceite oficial ficam registradas, mas não entram nas taxas (são as tentativas pós-aceite).

Quando uma correção vale. R: o alerta original sumiu na nova análise. F: os testes funcionais continuam passando. M: nenhum alerta novo apareceu. A correção é aceita quando R, F e M valem 1 ao mesmo tempo. F tem três definições: *sem separação* (todo teste conta), *marcador* (só ignora testes que afirmam um desafio resolvido) e *critério*, a oficial, que ignora os testes do conjunto D (seção 10).

2. Linha do tempo

Quando	O quê	Resultado
05/11	Piloto de 3 casos com os três modelos	Mostrou correções reprovadas por testes que exigem a vulnerabilidade. Foi criado o critério (d), ligado a casos.
05/11, 21:15	Fase oficial declarada	Primeira campanha de 78 casos, com conjunto D v2.
06/11, 03:39	Primeira campanha terminou	41, 36 e 31 casos aceitos. A conferência achou testes que ainda exigiam a vulnerabilidade.
06/11, manhã	Campanha descartada e revisão	O Caio descartou a campanha. Revisão de 172 pares de caso e teste e de 89 tentativas sem conclusão no Semgrep.
06/11	Correções	Conjunto D v3 (critério e), testes de contrato legítimo, comparador v3 e novo baseline. 422 testes unitários passando.
06/11, 07:55–14:20	Campanha final	GPT-6 Luna, GPT-5.6 Luna e GPT-4.1 mini, nessa ordem, sem erro.
06/11, 18:00–18:30	RRIS	Correções aceitas de cada modelo aplicadas juntas, sem LLM.

A primeira campanha não é evidência: os arquivos dela foram descartados e não estão no repositório. Ela aparece aqui porque explica as mudanças no conjunto D e no comparador.

3. Resultados por modelo

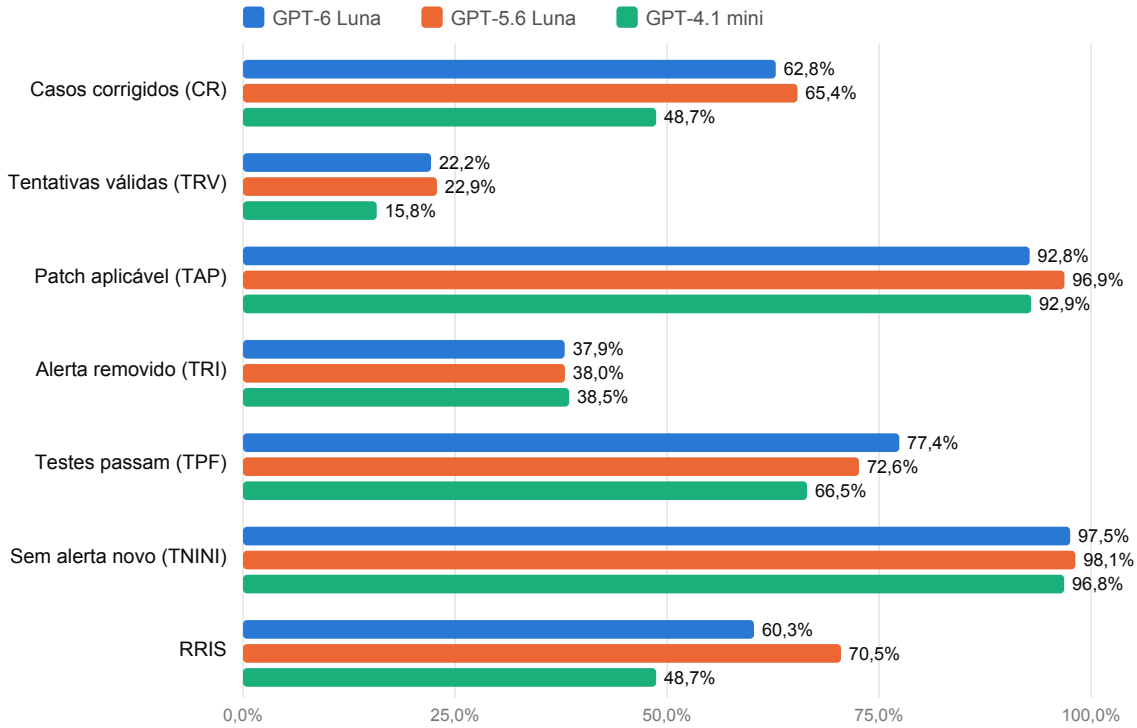


Figura 1. Métricas por modelo, definição oficial de F. Todas as barras usam a mesma escala de 0 a 100%.

Métrica	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
Casos corrigidos (CR)	62,8% (49/78)	65,4% (51/78)	48,7% (38/78)
Tentativas válidas (TRV)	22,2% (49/221)	22,9% (51/223)	15,8% (38/241)
Patch aplicável (TAP)	92,8% (205/221)	96,9% (216/223)	92,9% (224/241)
Alerta removido (TRI)	37,9% (77/203)	38,0% (82/216)	38,5% (85/221)
Testes passam (TPF)	77,4% (154/199)	72,6% (154/212)	66,5% (145/218)
Sem alerta novo (TNINI)	97,5% (198/203)	98,1% (212/216)	96,8% (214/221)
Falha funcional (TFF)	22,6% (45/199)	27,4% (58/212)	33,5% (73/218)
Aceitas com falha em D (TCD)	53,1% (26/49)	56,9% (29/51)	55,3% (21/38)
RRIS	60,3% (47/78)	70,5% (55/78)	48,7% (38/78)

Entre parênteses, numerador e denominador. TRI, TPF e TNINI usam só as tentativas em que a medida foi possível; a tabela abaixo repete as três com todas as tentativas no denominador.

Métrica	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
Alerta removido, todas as tentativas	34,8% (77/221)	36,8% (82/223)	35,3% (85/241)
Testes passam, todas as tentativas	69,7% (154/221)	69,1% (154/223)	60,2% (145/241)
Sem alerta novo, todas as tentativas	89,6% (198/221)	95,1% (212/223)	88,8% (214/241)

CR e TRV medem coisas diferentes

As duas têm o mesmo numerador e mudam no denominador. A CR divide pelos 78 casos; a TRV divide por todas as tentativas feitas até o primeiro aceite. Se P1 e P2 falham e P3 funciona, o caso conta 100% na CR e 1 de 3 na TRV. Por isso a TRV fica perto de 22%, enquanto a CR passa de 60% nos dois modelos Luna.

As três definições de F

Definição	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
Critério (oficial)	49 casos · TRV 22,2%	51 casos · TRV 22,9%	38 casos · TRV 15,8%
Marcador	23 casos · TRV 10,4%	22 casos · TRV 9,9%	17 casos · TRV 7,1%
Sem separação	23 casos · TRV 10,4%	22 casos · TRV 9,9%	17 casos · TRV 7,1%

Marcador e sem separação dão o mesmo resultado nesta execução: os testes de desafio resolvido não decidiram nenhum caso. A diferença para o critério oficial vem dos testes que exigem a vulnerabilidade (seção 10).

4. Do patch ao aceite

Cada etapa conta as tentativas que entram nas taxas (até o primeiro aceite de cada caso). A maior perda está em R: a maioria dos patches é aplicada e não cria alerta novo, mas não faz o Semgrep parar de apontar o alerta original.

Etapa	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
Tentativas que contam	221	223	241
Patch aplicado	205	216	224
Alerta removido (R=1)	77	82	85
Sem alerta novo (M=1)	198	212	214
R=1 e M=1	76	81	85
Testes passam (F=1)	154	154	145
Aceitas (R, F e M)	49	51	38

Resultado de cada tentativa

Resultado	Código	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
Alerta continua; testes e M ok	`rejeitada:R0F1M1`	101	101	102
Aceita	`aceita`	49	51	38
Alerta removido, mas testes falham	`rejeitada:R1F0M1`	22	28	42
Alerta continua e testes falham	`rejeitada:R0F0M1`	20	28	26
Resposta sem edição	`nao_aplicada:sem_edicoes`	15	3	1
Testes sem conclusão	`indeterminada_funcional`	6	4	6
Trecho do patch não encontrado	`nao_aplicada:ancora_nao_encontrada`	1	4	8
Alerta continua e surge alerta novo	`rejeitada:R0F1M0`	3	1	5
Trecho do patch ambíguo	`nao_aplicada:ancora_ambigua`	0	0	7
Semgrep sem conclusão	`indeterminada_sast`	2	0	3
Nada vale	`rejeitada:R0F0M0`	1	2	2
Alerta removido, mas surge outro	`rejeitada:R1F1M0`	1	1	0
Resposta fora do formato	`nao_aplicada:json_invalido`	0	0	1

Sem conclusão nos testes: em geral, correções que exigem uma variável de ambiente nova e impedem o módulo de carregar. Sem conclusão no Semgrep: problema de leitura do arquivo alterado.

5. Estratégias de prompt

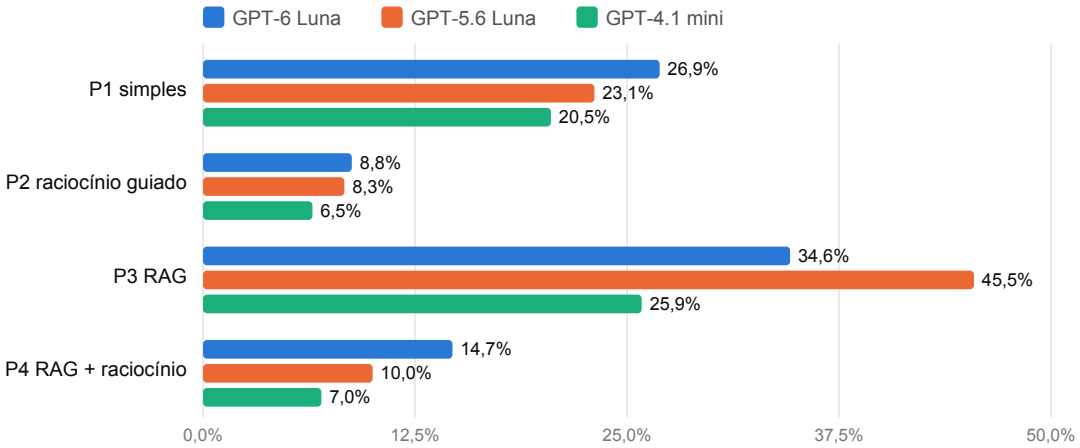


Figura 2. TRV por estratégia. Escala de 0 a 50%. P1 tenta os 78 casos; as demais só os que seguiram sem aceite estrito.

Estratégia	Modelo	Aceitas / tentativas	TRV	TRI	TPF	TAP
P1 simples	GPT-6 Luna	21/78	26,9%	37,5%	83,3%	92,3%
P1 simples	GPT-5.6 Luna	18/78	23,1%	32,0%	75,7%	96,2%
P1 simples	GPT-4.1 mini	16/78	20,5%	30,0%	78,9%	91,0%
P2 raciocínio guiado	GPT-6 Luna	5/57	8,8%	12,0%	76,9%	91,2%
P2 raciocínio guiado	GPT-5.6 Luna	5/60	8,3%	17,9%	71,4%	93,3%
P2 raciocínio guiado	GPT-4.1 mini	4/62	6,5%	14,3%	73,2%	90,3%
P3 RAG	GPT-6 Luna	18/52	34,6%	59,2%	78,3%	94,2%
P3 RAG	GPT-5.6 Luna	25/55	45,5%	63,6%	79,6%	100,0%
P3 RAG	GPT-4.1 mini	15/58	25,9%	61,8%	56,6%	96,6%
P4 RAG + raciocínio	GPT-6 Luna	5/34	14,7%	46,9%	62,1%	94,1%
P4 RAG + raciocínio	GPT-5.6 Luna	3/30	10,0%	43,3%	53,6%	100,0%
P4 RAG + raciocínio	GPT-4.1 mini	3/43	7,0%	55,0%	47,4%	95,3%

Leia com cuidado. As estratégias não recebem os mesmos casos: P2, P3 e P4 só tentam os casos que as anteriores não resolveram, que tendem a ser os mais difíceis. Mesmo assim, P3 (RAG) teve a maior TRV nos três modelos e foi a que mais removeu o alerta (TRI). P2 e P4, que acrescentam o roteiro de raciocínio, ficaram abaixo de P1 e P3.

Comparação pareada entre estratégias

Modelo	Par	Casos em comum	Só a primeira	Só a segunda	p (McNemar exato)
GPT-6 Luna	P1 × P2	72	4	5	1,0000
GPT-6 Luna	P1 × P3	67	6	19	0,0146
GPT-6 Luna	P2 × P3	67	4	19	0,0026
GPT-6 Luna	P3 × P4	57	2	10	0,0386
GPT-5.6 Luna	P1 × P2	73	1	5	0,2188
GPT-5.6 Luna	P1 × P3	69	2	26	0,0000
GPT-5.6 Luna	P2 × P3	69	2	26	0,0000
GPT-5.6 Luna	P3 × P4	57	5	3	0,7266
GPT-4.1 mini	P1 × P2	73	2	4	0,6875
GPT-4.1 mini	P1 × P3	71	4	17	0,0072
GPT-4.1 mini	P2 × P3	71	2	15	0,0023
GPT-4.1 mini	P3 × P4	61	0	4	0,1250

Usa as tentativas de todos os casos em que as duas estratégias rodaram, inclusive depois de um aceite. Não há correção para comparações múltiplas nesta tabela.

6. Resultados por tipo de caso

As tabelas desta seção contam casos corrigidos (CR), cada caso uma vez, separados por atributos do alerta.

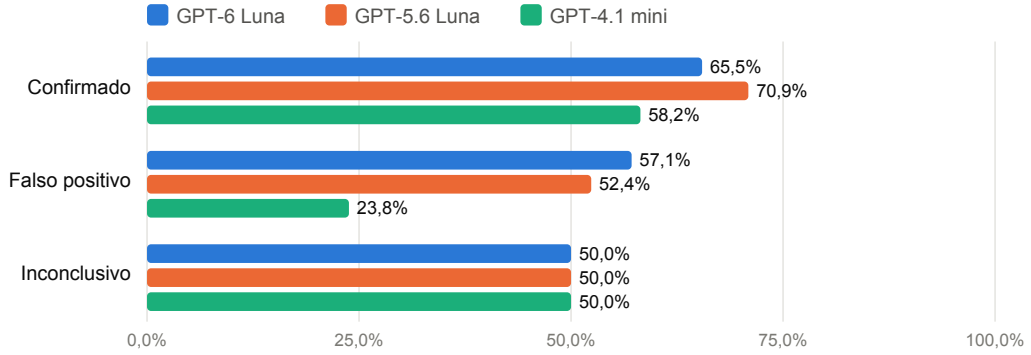


Figura 3. Casos corrigidos por resultado da triagem manual. Escala de 0 a 100%.

Triagem manual	Casos	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
Confirmado	55	36 (65%)	39 (71%)	32 (58%)
Falso positivo	21	12 (57%)	11 (52%)	5 (24%)
Inconclusivo	2	1 (50%)	1 (50%)	1 (50%)

Em um falso positivo, "corrigido" significa que o Semgrep parou de apontar sem quebrar os testes; não havia vulnerabilidade a corrigir.

Origem da regra	Casos	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
Regra própria	49	35 (71%)	38 (78%)	30 (61%)
Regra do registro	29	14 (48%)	13 (45%)	8 (28%)

As regras próprias foram escritas pelo grupo para alertas que o registro não cobria. Os modelos foram melhor nelas do que nas do registro.

Severidade do Semgrep	Casos	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
WARNING	69	42 (61%)	45 (65%)	35 (51%)

Severidade do Semgrep	Casos	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
ERROR	8	6 (75%)	5 (62%)	2 (25%)
INFO	1	1 (100%)	1 (100%)	1 (100%)

OWASP Top 10 2025	Casos	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
sem OWASP	49	35 (71%)	38 (78%)	30 (61%)
A05	8	5 (62%)	4 (50%)	3 (38%)
A01	6	3 (50%)	4 (67%)	1 (17%)
A06	5	3 (60%)	2 (40%)	4 (80%)
A07	4	0 (0%)	0 (0%)	0 (0%)
A04	3	3 (100%)	2 (67%)	0 (0%)
A02	2	0 (0%)	1 (50%)	0 (0%)
A08	1	0 (0%)	0 (0%)	0 (0%)

"Sem OWASP" são as regras próprias, que não trazem a categoria do OWASP no metadado.

Documento da base de conhecimento (P3 e P4)

Documento recebido no prompt	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
broken_access_control	4/19	5/14	4/21
security_misconfiguration	4/12	6/13	1/20
cryptographic_failures	4/15	4/14	2/16
path_traversal	5/11	3/11	4/8
cross_site_scripting	0/8	1/9	0/8
injection	3/3	3/5	2/9
input_validation	2/5	4/6	3/5
mass_assignment	0/4	0/4	0/4
authentication_failures	1/3	1/3	1/3
integrity_failures	0/2	0/2	0/2
open_redirect	0/2	0/2	0/2
concurrency	0/2	0/0	0/2
ssrf	0/0	1/2	1/1

Aceitas sobre tentativas de P3 e P4 que contam, pelo documento que o prompt recebeu.

Por CWE

CWE	Casos	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
CWE-79	12	8 (67%)	8 (67%)	8 (67%)
CWE-639	8	6 (75%)	7 (88%)	3 (38%)
CWE-73	6	5 (83%)	3 (50%)	5 (83%)
CWE-20	4	3 (75%)	3 (75%)	3 (75%)
CWE-200	4	4 (100%)	3 (75%)	1 (25%)
CWE-548	4	2 (50%)	3 (75%)	0 (0%)
CWE-798	4	0 (0%)	0 (0%)	0 (0%)
CWE-943	4	4 (100%)	4 (100%)	3 (75%)
CWE-95	4	4 (100%)	3 (75%)	3 (75%)
CWE-321	3	3 (100%)	2 (67%)	0 (0%)
CWE-1333	2	0 (0%)	1 (50%)	0 (0%)
CWE-601	2	1 (50%)	1 (50%)	1 (50%)
CWE-862	2	0 (0%)	1 (50%)	1 (50%)
CWE-863	2	0 (0%)	0 (0%)	0 (0%)
CWE-89	2	2 (100%)	2 (100%)	1 (50%)
CWE-915	2	0 (0%)	0 (0%)	0 (0%)
CWE-916	2	1 (50%)	2 (100%)	2 (100%)
CWE-134	1	1 (100%)	1 (100%)	1 (100%)
CWE-22	1	0 (0%)	0 (0%)	0 (0%)
CWE-307	1	1 (100%)	1 (100%)	1 (100%)
CWE-345	1	0 (0%)	0 (0%)	0 (0%)
CWE-362	1	0 (0%)	1 (100%)	0 (0%)
CWE-522	1	0 (0%)	0 (0%)	0 (0%)
CWE-611	1	1 (100%)	1 (100%)	1 (100%)
CWE-620	1	1 (100%)	1 (100%)	1 (100%)
CWE-807	1	0 (0%)	1 (100%)	1 (100%)
CWE-841	1	1 (100%)	1 (100%)	1 (100%)
CWE-918	1	1 (100%)	1 (100%)	1 (100%)

7. Comparação entre modelos

Os três modelos receberam os mesmos 78 casos, então a comparação é pareada: interessa só onde um corrigiu e o outro não. O teste usado é o McNemar exato.

Par	Os dois	Só o primeiro	Só o segundo	Nenhum	p	p corrigido (×3)
GPT-6 Luna × GPT-5.6 Luna	43	6	8	21	0,7905	1,0000
GPT-6 Luna × GPT-4.1 mini	33	16	5	24	0,0266	0,0798
GPT-5.6 Luna × GPT-4.1 mini	36	15	2	25	0,0023	0,0069

O p corrigido usa Bonferroni para as três comparações. GPT-5.6 Luna e GPT-6 Luna não se distinguem. A vantagem do GPT-5.6 Luna sobre o GPT-4.1 mini continua clara depois da correção; a do GPT-6 Luna sobre o GPT-4.1 mini deixa de ser.

Uma execução por modelo. A LLM não responde igual a cada vez. Entre a campanha descartada e a final, cada modelo deixou de corrigir de 2 a 4 casos que antes passavam. As diferenças pequenas entre modelos devem ser lidas com isso em mente.

8. RRIS: as correções aplicadas juntas

Até aqui, cada correção foi testada sozinha. A RRIS aplica numa mesma cópia todas as correções aceitas de um modelo, na ordem em que foram feitas, passa o Semgrep no projeto inteiro e calcula (alertas antes − alertas depois) / alertas antes. Correções que não se encaixam sobre as anteriores ficam de fora e aparecem como conflito. Não há chamada à LLM.

Modelo	RRIS	Alertas	Correções aplicadas	Em conflito	Conjunto passa nos testes?
GPT-6 Luna	60,3%	78 → 31	40	9	não
GPT-5.6 Luna	70,5%	78 → 23	43	8	não
GPT-4.1 mini	48,7%	78 → 40	34	4	não

Uma correção pode remover mais de um alerta; por isso a redução pode passar do número de correções.

Por que nenhum conjunto passou nos testes

Teste	Causa	Tipo
POST login newly created user	Cria um usuário sem passwordRepeat; falha com a correção do caso AMP8655da	Exige a falha
persists and lists normal feedback through the generated resource	Usa a resposta do CAPTCHA devolvida pelo servidor; falha com a correção do caso AMP4d38ad	Exige a falha
keeps every last IP scenario and detects missing and fabricated addresses	Falha só com as correções de AMP986bde e AMP417d1d juntas	Interação

GPT-5.6 Luna e GPT-6 Luna têm as três falhas; o GPT-4.1 mini, as duas primeiras. Os dois primeiros testes também exigem a vulnerabilidade, mas só aparecem na validação conjunta, porque testando cada correção sozinha esses grupos não rodam. Nada foi alterado: a RRIS é reportada como redução no Semgrep, sem validação funcional do conjunto.

9. Custo, tokens, tempo e cache

Modelo	Custo	Por caso corrigido	Tokens de entrada	Tokens de saída	Entrada vinda do cache da OpenAI	Duração
GPT-6 Luna	US$ 0,14	US$ 0,0028	563.266	153.481	11,6% (32)	2h02
GPT-5.6 Luna	US$ 0,31	US$ 0,0062	574.447	156.186	11,0% (30)	2h12
GPT-4.1 mini	US$ 0,43	US$ 0,0114	587.207	155.015	28,2% (81)	2h10

Modelo	LLM por tentativa	Semgrep por tentativa	Testes por tentativa	Tentativas	Pós-aceite	Chamadas
GPT-6 Luna	6,0 s	46,1 s	50,8 s	274	53	274
GPT-5.6 Luna	6,9 s	47,2 s	52,1 s	277	54	277
GPT-4.1 mini	5,8 s	49,7 s	50,2 s	283	42	283

Tempos médios por tentativa. A duração é de relógio, do início ao fim de cada modelo, com quatro tentativas em paralelo.

Cache

- **Cache do pipeline: desligado.** Todas as tentativas fizeram chamada real à LLM; nenhuma resposta foi reaproveitada. Nenhum resultado do Semgrep ou dos testes foi reaproveitado (0 reusos registrados).
- **Cache automático da OpenAI: presente em parte das chamadas.** Quando o começo de um prompt repete o de uma chamada recente, a OpenAI reaproveita o processamento da entrada e cobra menos. A resposta é gerada de novo; isso muda o custo, não o resultado. A coluna da tabela acima mostra a parte da entrada que veio desse cache e, entre parênteses, quantas tentativas o usaram.
- Raciocínio estendido desligado nos modelos Luna (0 tokens de raciocínio). Uma resposta do GPT-4.1 mini parou pelo limite de 4.096 tokens de saída.

10. Testes desconsiderados (conjunto D)

Alguns testes do Juice Shop só passam enquanto a vulnerabilidade existe: afirmam que um desafio foi resolvido, mandam um ataque e esperam sucesso, ou dependem do comportamento inseguro para preparar o cenário. Uma correção certa reprova esses testes. Eles formam o conjunto D e não reprovam a correção na definição oficial de F. **Eles continuam rodando:** a falha fica registrada e entra na TCD, mas não cobra que a vulnerabilidade continue existindo.

O conjunto D v3 tem **138 testes**: 88 que não contam em nenhum caso e 50 que não contam só nos casos ligados a eles (27 casos). Por critério: (a) 36, (b) 29, (c) 10, (d) 50, (e) 13. Por pasta: test/api 92, test/server 38, frontend 6, tests/functional 2. Lista completa no Apêndice B.

Critério	Quando o teste entra em D	Abrangência
(a)	Afirma que um desafio do Juice Shop foi resolvido	todos os casos
(b)	Envia um ataque conhecido e espera sucesso	todos os casos
(c)	Afirma que o ataque foi interpretado (SQL, template, código)	todos os casos
(d)	Fixa o mecanismo do alerta de um caso, inclusive como preparação do teste	só os casos ligados
(e)	A finalidade do teste é a própria falha (criado em 06/11/2026)	todos os casos

Por que não inverter o resultado. Contar a falha desses testes como aprovação foi descartado: uma falha por outro motivo, como o servidor não subir, viraria aprovação, e o mesmo teste reprovaria tentativas de casos sem relação com ele. Os testes do Juice Shop também não foram apagados, porque a pasta do alvo é conferida por hash.

Mudanças da versão 3 (06/11/2026)

22 testes entraram ou mudaram de abrangência depois da revisão dos 172 pares de caso e teste reprovados na campanha descartada. Os do critério (e):

Teste	Arquivo	Motivo	Falhas
PUT update existing product is possible due to Missing Function-Level Access Control vulnerability	`test/api/product.test.ts`	Altera um produto sem credencial e espera sucesso.	16
GET who-am-i with fields parameter can be tricked into returning password	`test/api/user.test.ts`	Exige que a resposta traga a senha.	22
GET serves a directory listing	`test/api/ftp-folder.test.ts`	Exige a página de listagem de /ftp.	19
GET serves a directory listing	`test/api/file-serving.test.ts`	Exige a página de listagem de /encryptionkeys.	5
GET folder containing access log files for "Access Log" challenge	`test/api/file-serving.test.ts`	Exige baixar o log de acesso sem credencial.	6
GET access log file for the current day	`test/api/logfile-server.test.ts`	Exige baixar o log de acesso sem credencial.	5
GET error message with information leakage when calling /redirect without query parameter	`test/api/redirect.test.ts`	Exige a mensagem de erro interna na resposta.	0
GET error message with information leakage when calling /redirect with unrecognized query parameter	`test/api/redirect.test.ts`	Exige a mensagem de erro interna na resposta.	0
GET error message with information leakage when calling unrecognized path with /rest in it	`test/api/api.test.ts`	Exige a mensagem de erro interna na resposta.	0
POST erasure request with non-existing file path as layout parameter throws error	`test/api/erasure-request.test.ts`	Exige que o layout do cliente chegue ao sistema de arquivos.	13
POST sandbox breakout attack in "orderLinesData" will raise error	`test/api/b2b-order.test.ts`	O erro só existe se o código enviado pelo cliente for avaliado.	2
POST endless loop exploit in "orderLinesData" will raise explicit error	`test/api/b2b-order.test.ts`	O erro só existe se o código enviado pelo cliente for avaliado.	5
POST busy spinning regex attack does not raise an error	`test/api/b2b-order.test.ts`	O erro só existe se o código enviado pelo cliente for avaliado.	5

Novos testes ligados a casos, critério (d):

Teste	Arquivo	Casos	Motivo
should return 500 if QuantityModel.findOne fails during checkout	`test/api/basket.test.ts`	bd16f4	bjoern fecha o carrinho 4, da amy, e espera chegar à consulta de estoque.
POST feedback is associated with current user	`test/api/feedback.test.ts`	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
POST feedback is associated with any passed user ID	`test/api/feedback.test.ts`	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
does not discount a campaign with a mismatched date	`tests/functional/juice_shop/campaign_discount.test.ts`	ab8d19	Exige que a data enviada pelo cliente continue decidindo o desconto.
PATCH single product review can be edited	`test/api/product-review.test.ts`	3d463b, 4a7e01	Token sem usuário edita a avaliação de outra pessoa e espera sucesso.
should cycle through the available carousel images when there are more feedbacks than images	`frontend/src/app/about/about.component.spec.ts`	746c0b	O mock só oferece bypassSecurityTrustHtml, que é o sink apontado pelo alerta.
POST with non-OK response falls back to storing URL as profile image	`test/api/profile-image-upload.test.ts`	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
POST with empty-body response (204) falls back to storing URL as profile image	`test/api/profile-image-upload.test.ts`	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
POST with valid response writes file and redirects to profile	`test/api/profile-image-upload.test.ts`	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
POST with PNG URL extension saves file using PNG extension	`test/api/profile-image-upload.test.ts`	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
POST with unrecognised URL extension defaults to JPG extension	`test/api/profile-image-upload.test.ts`	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
GET promotion video page contains subtitles as <script>	`test/api/promotion-video.test.ts`	593661, c03720, f50218	Exige as legendas dentro da tag script apontada pelo alerta.
should expand internal entities	`test/server/xml.unit.test.ts`	f7a5e2	Exige a expansão de entidades que o alerta manda desligar.
PUT update basket ID of basket item without basket ID	`test/api/basket-item.test.ts`	af8889, ba6a42	jim move um item para o carrinho 3, do bender, e espera sucesso.

Examinados e mantidos em F

Teste	Por que continua contando
GET own previous orders; Export data including orders	Os pedidos estão gravados com o e-mail mascarado; o patch que troca só a consulta devolve lista vazia.
GET product reviews by product id	O patch compara o id em texto com um número e não acha nenhuma avaliação.
calculates and persists 2+3*4 = 14	O patch ignora a precedência das operações.
increments the selected review once and rejects the same user twice	Os patches devolvem 400, contam em dobro ou aceitam curtida repetida.
preserves deterministic distinct digests without pinning a secret	Sal aleatório quebra o login; chave lida de variável obrigatória não sobe sem configuração.
should store the captcha on getting new captcha	Sem bypassSecurityTrustHtml, o Angular remove o SVG e o CAPTCHA some da tela.
keeps every last IP scenario...	Trocar o token do teste por texto qualquer destrói o cenário testado.
writes a correctly labelled checksum...	O patch grava SHA-256 em arquivo com rótulo .md5.
GET redirected to ... (destinos permitidos)	O patch restringe demais a lista de destinos.

Esses testes reprovam uma quebra real, não a correção.

Testes novos e corrigidos

`tests/functional/juice_shop/contratos_legitimos.test.ts` cobre o que os testes retirados também protegiam: editar a própria avaliação, recusar redirecionamento sem destino e salvar a imagem de perfil vinda de uma URL pública. Ele passa no código original e com as correções boas, e reprovou os patches que quebravam a edição de avaliações. `server_startup.unit.test.ts` exigia a forma concatenada do log e passou a olhar o texto registrado. Não foi criado substituto para PUT /api/Products/:id porque a correção oficial do Juice Shop desliga essa rota.

Quanto o conjunto D pesou

Modelo	Aceitas com falha em D	TCD
GPT-6 Luna	26 de 49	53,1%
GPT-5.6 Luna	29 de 51	56,9%
GPT-4.1 mini	21 de 38	55,3%

Sem o conjunto D, os casos aceitos cairiam para menos da metade (seção 3). Os testes de D que mais falharam:

Teste	Arquivo	Tentativas	Casos
GET who-am-i with fields parameter can be tricked into returning password	`test/api/user.test.ts`	22	4
GET serves a directory listing	`test/api/ftp-folder.test.ts`	19	4
PUT update existing product is possible due to Missing Function-Level Access Control vulnerability	`test/api/product.test.ts`	16	3
POST erasure request with existing file path as layout parameter returns content truncated	`test/api/erasure-request.test.ts`	14	2
POST erasure request with non-existing file path as layout parameter throws error	`test/api/erasure-request.test.ts`	13	2
PATCH multiple product review via injection	`test/api/product-review.test.ts`	8	2
GET user profile renders evaluated SSTI payload for username containing valid expression	`test/api/user-profile.test.ts`	8	2
calculates and persists 2+3*4 = 14	`tests/functional/juice_shop/captcha_arithmetic.test.ts`	8	1
calculates and persists 2-3*4 = -10	`tests/functional/juice_shop/captcha_arithmetic.test.ts`	8	1
POST new user with XSS attack in email address	`test/api/user.test.ts`	7	3
should pass the search query as trusted HTML	`frontend/src/app/search-result/search-result.component.spec.ts`	6	2
should render product descriptions as trusted HTML	`frontend/src/app/search-result/search-result.component.spec.ts`	6	2
POST placing an order for a basket with a negative total cost is possible	`test/api/basket.test.ts`	6	2
POST fails to sanitize masked XSS-attack by not applying sanitization recursively	`test/api/feedback.test.ts`	6	2
GET folder containing access log files for "Access Log" challenge	`test/api/file-serving.test.ts`	6	2

11. Comparador do Semgrep

Para decidir R e M, o pipeline compara os alertas antes e depois do patch. Quando um alerta muda de linha, ele precisa ser reconhecido como o mesmo. Na campanha descartada, a versão anterior do comparador deixou 89 tentativas sem conclusão no Semgrep; em 84 delas o alerta só tinha mudado de lugar.

A versão usada agora (`ocorrencias_contexto_v3`) resolve esses casos pela contagem da mesma regra no mesmo arquivo: contagem igual ou maior mantém o alerta alvo (R=0); um aumento conta como alerta novo (M=0); contagem igual não é alerta novo. Problemas de leitura do arquivo continuam sem conclusão. Na campanha final, sobraram 2, 0 e 3 tentativas sem conclusão no Semgrep entre as que contam.

Limitação. Um alerta removido e outro igual criado no mesmo arquivo contam como o mesmo. Quando o alerta alvo está nesse grupo, a tentativa é rejeitada de qualquer forma; nos outros casos, a inspeção manual cobre o

risco.

12. Limitações

- **Uma execução por modelo.** A LLM varia entre execuções; diferenças de poucos casos podem ser ruído.
- **Critérios ajustados depois de ver resultados.** O conjunto D v3 e o comparador v3 nasceram da campanha descartada. A mesma regra vale para os três modelos, cada entrada é justificada pela asserção do teste e a campanha que motivou a mudança não é usada como resultado.
- **R=1 não prova que a vulnerabilidade sumiu.** Só diz que o Semgrep parou de apontar. Não houve prova de exploração nem inspeção manual das correções aceitas.
- **Testes em D não protegem a função.** Uma correção que apague uma funcionalidade coberta só por testes de D pode passar. Os contratos legítimos cobrem parte disso.
- **Cobertura funcional limitada.** Só rodam os grupos de teste ligados aos arquivos alterados; testes de frontend usam jsdom e mocks, não um navegador.
- **Estratégias em cadeia.** P2, P3 e P4 recebem só os casos que sobraram; as taxas por estratégia não mostram efeito causal.
- **Um teste do próprio grupo reprovou uma correção oficial.** `creates reads and updates a product` exige PUT autenticado e reprovou o denyAll() do GPT-6 Luna no caso AMP095fcc. O grupo decidiu manter 49 casos (seriam 50).
- **RRIS sem validação funcional do conjunto** (seção 8), com 4 a 9 correções fora do conjunto por conflito.
- **Correções que exigem configuração nova.** Patches que leem uma chave obrigatória de variável de ambiente impedem o módulo de carregar nos testes e ficam sem conclusão em F.
- **Base de conhecimento.** Oito documentos da base 2.1 foram alterados sem revisão humana.
- **TRV-P não calculada.** Falta definir os pesos por severidade.

13. Onde estão os arquivos e como reproduzir

O quê	Onde
Campanha (um por modelo)	`outputs/campanha_docker/AMP_REAL_20261106T*/ e *_METRICAS/`
Logs da campanha	`outputs/campanha_docker/OFICIAL_20261106_<modelo>.console.log`
RRIS e métricas finais	`outputs/rris/<EXECUCAO>/ e outputs/rris/<EXECUCAO>_METRICAS/`
Baseline funcional	`outputs/cobertura_funcional/IMAGEM_81FE_D3_20261106/`
Conjunto D, revisão e mapa	`config/conjunto_d_cobertura_v3.json, config/cobertura_funcional_v8.yaml, config/mapa_testes_relacionados_v9.yaml`
Regras do conjunto D	`docs/criterios_conjunto_d.md e docs/conjunto_d.md (seção Versão 3)`
Incidentes e decisões	`docs/caderno_de_laboratorio.md (entradas de 05 e 06/11/2026)`
Este relatório	`scripts/relatorios/dados_execucao_oficial.py e gerar_relatorio_pdf.py`

Campanha de um modelo (troque o nome do modelo). Leva cerca de 2 horas por modelo e precisa do Mac na tomada, com a tampa aberta e `caffeinate -dis`:

```
TCC_DOCKER_IMAGE=sha256:81fe6403f07a05ccf7a911211e54ff2ae44c6b12237768b0a84ec1c7167ff5be \
  docker compose run --rm --no-deps tcc .venv/bin/python executar.py \
  --config config/execucao_docker_78.yaml --modelo gpt-6-luna --modo real
```

RRIS de uma execução, sem LLM; depois, `scripts/relatorios/consolidar_metricas.py --evidencia-rris` publica as métricas:

```
docker compose run -T --rm --no-deps tcc .venv/bin/python scripts/experimento/avaliacao_conjunta_rris.py \
  --entrada outputs/campanha_docker/<EXECUCAO> --execucao <EXECUCAO> --saida outputs/rris/<EXECUCAO> \
  --baseline-testes outputs/cobertura_funcional/IMAGEM_81FE_D3_20261106/baseline/baseline_testes.json
```

O baseline só vale para a imagem em que foi gerado. Para rodar em outra imagem, como a do Matheus, é preciso gerar um baseline novo nela (cerca de 5 minutos), sem misturar modelos entre máquinas. O limite de chamadas do `.env` foi aumentado para

2.500.

14. O que falta

- **Inspeção manual** de uma amostra das correções aceitas e de algumas rejeitadas, para confirmar que corrigem a vulnerabilidade e não só o alerta.
- **TRV-P**: decidir os pesos por severidade, se ela for entrar no artigo.
- **Revisão humana** dos oito documentos alterados da base de conhecimento.
- **Artigo**: mostrar CR, TRV, TAP, TRI, TPF, TNINI, TFF, TCD e RRIS, as três definições de F e a comparação pareada, com as limitações da seção 12.
- **Dashboard** local dos resultados, em construção a partir do mesmo arquivo de dados deste relatório.

Apêndice A. Os 78 casos

Para cada modelo, a estratégia em que o caso foi aceito pela primeira vez; travessão quando nenhuma tentativa foi aceita. Triagem: conf. = confirmado, FP = falso positivo, inc. = inconclusivo.

Caso	Regra	Arquivo:linha	Triagem	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
fd83fe	md5-hash	`Gruntfile.js:75`	FP	P4	P3	P3
445543	detected-generic-secret	`data/static/users.yml:151`	conf.	—	—	—
746c0b	bypass-security-trust-html	`frontend/src/app/about/about.component.ts:119`	conf.	P1	P3	P2
d3ce84	bypass-security-trust-html	`frontend/src/app/administration/administration.component.ts:73`	conf.	P2	P2	P1
9bd88c	bypass-security-trust-html	`frontend/src/app/administration/administration.component.ts:91`	conf.	P1	P1	P1
dbe817	detected-jwt-token	`frontend/src/app/app.guard.spec.ts:46`	FP	P3	P3	—
dcb27f	bypass-security-trust-html	`frontend/src/app/data-export/data-export.component.ts:57`	FP	—	—	—
986bde	detected-jwt-token	`frontend/src/app/last-login-ip/last-login-ip.component.spec.ts:72`	FP	P3	P3	—
755998	detected-jwt-token	`frontend/src/app/last-login-ip/last-login-ip.component.spec.ts:78`	FP	P3	—	—
417d1d	bypass-security-trust-html	`frontend/src/app/last-login-ip/last-login-ip.component.ts:39`	conf.	P1	P1	P1
7ad569	bypass-security-trust-html	`frontend/src/app/score-board/score-board.component.ts:82`	FP	P1	P1	P1
ad5710	bypass-security-trust-html	`frontend/src/app/search-result/search-result.component.ts:110`	conf.	P2	P1	P1
5bc31b	bypass-security-trust-html	`frontend/src/app/search-result/search-result.component.ts:143`	conf.	P1	P1	P1
5ea334	bypass-security-trust-html	`frontend/src/app/track-result/track-result.component.ts:48`	conf.	P1	P1	P1
d53a8f	prototype-pollution-loop	`frontend/src/hacking-instructor/helpers/helpers.ts:49`	FP	—	—	—
15048b	detect-non-literal-regexp	`lib/codingChallenges.ts:76`	FP	—	P4	—
6d2d86	detect-non-literal-regexp	`lib/codingChallenges.ts:78`	FP	—	—	—
41302b	md5-hash	`lib/insecurity.ts:41`	conf.	—	P3	P3
f9cfca	hardcoded-hmac-key	`lib/insecurity.ts:42`	conf.	—	—	—
3aec6c	hardcoded-jwt-secret	`lib/insecurity.ts:54`	conf.	—	—	—
38978d	encoded-numeric-value	`lib/insecurity.ts:112`	conf.	—	—	—
337831	substring-allowlist	`lib/insecurity.ts:135`	conf.	P1	P1	P1
60988b	hardcoded-hmac-key	`lib/insecurity.ts:150`	conf.	—	—	—
f7a5e2	external-entity-expansion	`lib/xml.ts:35`	conf.	P1	P1	P1
ff4689	rating-without-range	`models/feedback.ts:57`	conf.	P4	P3	P3
317527	untrusted-evaluator	`routes/b2bOrder.ts:23`	conf.	P1	P3	P1
966898	request-id-unscoped-query	`routes/basket.ts:19`	conf.	—	P3	P4
af8889	first-last-mismatch	`routes/basketItems.ts:42`	conf.	P1	P3	P2
ba6a42	request-id-unscoped-query	`routes/basketItems.ts:68`	inc.	P3	P3	—
decc0f	quantity-upper-bound-only	`routes/basketItems.ts:93`	conf.	—	—	—
869de4	eval-detected	`routes/captcha.ts:22`	FP	P2	—	—
4d38ad	answer-in-response	`routes/captcha.ts:31`	conf.	P3	P3	P4
9ea0dd	optional-current-password	`routes/changePassword.ts:39`	conf.	P1	P1	P2
1f800f	dynamic-where	`routes/chat.ts:149`	FP	P1	P2	P1
18ca95	remote-property-injection	`routes/currentUser.ts:31`	conf.	—	—	—
2bf027	jsonp-response	`routes/currentUser.ts:58`	conf.	P3	P3	—
709232	render-request-options	`routes/dataErasure.ts:107`	conf.	P4	P3	P1
a39e4f	render-request-options	`routes/dataErasure.ts:123`	FP	P3	—	—

Caso	Regra	Arquivo:linha	Triagem	GPT-6 Luna	GPT-5.6 Luna	GPT-4.1 mini
fb70ed	masked-email-selector	routes/dataExport.ts:33	conf.	—	—	—
d55302	request-id-unscoped-query	routes/delivery.ts:34	FP	—	—	—
8acdcd	optional-mode-role-update	routes/deluxe.ts:43	conf.	P1	P3	P3
994f19	express-res-sendfile	routes/fileServer.ts:33	conf.	P3	P3	P3
9fadf8	entry-path-write	routes/fileUpload.ts:34	conf.	—	—	—
95adf5	express-res-sendfile	routes/keyServer.ts:14	conf.	P3	P3	P3
5c9cd8	delayed-counter-update	routes/likeProductReviews.ts:35	conf.	—	P2	—
4d17cf	unscoped-document-write	routes/likeProductReviews.ts:36	FP	P2	P1	—
0cc5ea	unscoped-document-write	routes/likeProductReviews.ts:51	FP	P4	P1	P2
b65a14	express-res-sendfile	routes/logfileServer.ts:14	conf.	P4	—	P3
fb1545	express-sequelize-injection	routes/login.ts:34	conf.	P1	P1	P1
bd16f4	request-id-unscoped-query	routes/order.ts:35	conf.	P1	P3	—
ab8d19	client-campaign-date	routes/order.ts:201	conf.	—	P4	P3
0de511	masked-email-selector	routes/orderHistory.ts:17	conf.	—	—	—
2ce118	unscoped-document-write	routes/orderHistory.ts:36	FP	P3	P2	—
f6324e	request-url-fetch	routes/profileImageUrlUpload.ts:24	conf.	P1	P4	P3
a4fbc8	express-res-sendfile	routes/quarantineServer.ts:14	inc.	—	—	P3
7f1628	express-open-redirect	routes/redirect.ts:19	conf.	—	—	—
2ab02d	express-sequelize-injection	routes/search.ts:23	conf.	P1	P1	—
58b496	dynamic-where	routes/showProductReviews.ts:36	conf.	P1	P2	—
20721d	dynamic-where	routes/trackOrder.ts:18	conf.	P1	P1	P1
3d463b	untrusted-id-multi-update	routes/updateProductReviews.ts:17	conf.	P1	P3	P4
4a7e01	unscoped-document-write	routes/updateProductReviews.ts:18	conf.	P3	P3	P3
6fe766	code-string-concat	routes/userProfile.ts:61	conf.	P3	P1	P1
d5224d	eval-detected	routes/userProfile.ts:61	conf.	P3	P1	P1
f50218	unknown-value-with-script-tag	routes/videoHandler.ts:57	FP	—	—	—
593661	unknown-value-with-script-tag	routes/videoHandler.ts:71	conf.	—	—	—
dff9fb	unsafe-formatstring	server.ts:157	FP	P3	P3	P3
ee9d50	express-check-directory-listing	server.ts:269	conf.	P3	P3	—
8736e1	express-check-directory-listing	server.ts:273	FP	—	P3	—
5b6593	express-check-directory-listing	server.ts:277	conf.	—	P3	—
44846a	express-check-directory-listing	server.ts:281	conf.	P3	—	—
dab2e8	trust-all-proxies-rate-limit	server.ts:342	conf.	P3	P3	P3
095fcc	asymmetric-method-guard	server.ts:371	conf.	—	P1	P3
8655da	optional-validation-gate	server.ts:409	conf.	P3	P3	P3
ed3156	asymmetric-method-guard	server.ts:429	FP	—	—	—
2d60f2	generated-default-writes	server.ts:501	conf.	—	—	—
8be00f	public-metrics-route	server.ts:676	conf.	P2	P1	—
488a4d	public-metrics-route	server.ts:729	conf.	P1	—	—
c03720	template-explicit-unescape	views/promotionVideo.pug:75	FP	—	—	—

Apêndice B. Conjunto D v3 completo

Os testes listados não reprovam a correção na definição oficial de F. "todos": vale em todos os casos.

Crit.	Teste	Arquivo	Casos	Motivo
(b)	GET basket should accept forged JWTs	test/api/basket.test.ts	todos	JWT sem assinatura (alg none) aceito: 200
(b)	GET existing basket of another user	test/api/basket.test.ts	todos	cesta de outro usuario (IDOR) devolvida: 200
(b)	POST placing an order for a basket with a negative total cost is possible	test/api/basket.test.ts	todos	pedido com total negativo confirmado
(b)	POST placing an order for a basket with 99% discount is possible	test/api/basket.test.ts	todos	cupom forjado com 99% de desconto aceito
(a)	POST private key in request body gets accepted	test/api/checkKeys.test.ts	todos	asserção de desafio resolvido
(b)	POST erasure request with existing file path as layout parameter returns content truncated	test/api/erasure-request.test.ts	todos	layout '../package.json' devolve o arquivo
(c)	POST fails to sanitize masked XSS-attack by not applying sanitization recursively	test/api/feedback.test.ts	todos	iframe javascript: gravado sem neutralizacao
(b)	POST feedback in another users name as anonymous user	test/api/feedback.test.ts	todos	feedback anonimo gravado em nome de outro usuario
(b)	GET the easter egg file by using Poison Null Byte attack with .pdf suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the easter egg file by using Poison Null Byte attack with .md suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the SIEM signature file by using Poison Null Byte attack with .pdf suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the SIEM signature file by using Poison Null Byte attack with .md suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the 2013 coupon code file by using Poison Null Byte attack with .pdf suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the 2013 coupon code file by using an Poison Null Byte attack with .md suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the package.json.bak file by using Poison Null Byte attack with .pdf suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the package.json.bak file by using Poison Null Byte attack with .md suffix	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera arquivo restrito
(b)	GET the package.json.bak file contains a dependency on epilogue-js for "Typosquatting" challenge	test/api/ftp-folder.test.ts	todos	null byte (%2500) libera package.json.bak
(b)	POST login with WHERE-clause disabling SQL injection attack	test/api/login.test.ts	todos	SQL injection devolve token
(b)	POST login with known email "admin@juice-sh.op" in SQL injection attack	test/api/login.test.ts	todos	SQL injection devolve token
(b)	POST login with known email "jim@juice-sh.op" in SQL injection attack	test/api/login.test.ts	todos	SQL injection devolve token
(b)	POST login with known email "bender@juice-sh.op" in SQL injection attack	test/api/login.test.ts	todos	SQL injection devolve token
(b)	POST login with non-existing email "acc0unt4nt@juice-sh.op" via UNION SELECT injection attack	test/api/login.test.ts	todos	UNION SELECT devolve token
(a)	GET with a regular browser user agent solves exposedMetricsChallenge	test/api/metrics.test.ts	todos	asserção de desafio resolvido
(a)	POST minted wallet address successfully solves minting challenge	test/api/nftMint.test.ts	todos	asserção de desafio resolvido
(b)	GET product reviews attack by injecting a mongoDB sleep command	test/api/product-review.test.ts	todos	injecao NoSQL sleep(1) aceita: 200
(b)	PATCH multiple product review via injection	test/api/product-review.test.ts	todos	injecao NoSQL ($ne) altera todas as avaliacoes
(c)	POST new product does not filter XSS attacks	test/api/product.test.ts	todos	iframe javascript: gravado sem neutralizacao
(b)	GET redirected to target URL in "to" parameter when a allow-listed URL is part of the query string	test/api/redirect.test.ts	todos	allowlist contornada pela query string: 200

Crit.	Teste	Arquivo	Casos	Motivo
(c)	GET product search fails with error message that exposes ins SQL Injection vulnerability	test/api/search.test.ts	todos	vazamento de erro de SQL (SQLITE_ERROR)
(c)	GET product search SQL Injection fails from two missing closing parenthesis	test/api/search.test.ts	todos	vazamento de erro de SQL (SQLITE_ERROR)
(c)	GET product search SQL Injection fails from one missing closing parenthesis	test/api/search.test.ts	todos	vazamento de erro de SQL (SQLITE_ERROR)
(c)	GET product search SQL Injection fails for SELECT * FROM attack due to wrong number of returned columns	test/api/search.test.ts	todos	vazamento de erro de SQL (SQLITE_ERROR)
(b)	GET product search can create UNION SELECT with Users table and fixed columns	test/api/search.test.ts	todos	UNION SELECT devolve linhas injetadas
(b)	GET product search can create UNION SELECT with Users table and required columns	test/api/search.test.ts	todos	UNION SELECT devolve usuarios e hashes
(b)	GET product search can create UNION SELECT with sqlite_master table and required column	test/api/search.test.ts	todos	UNION SELECT devolve o esquema (sqlite_master)
(b)	GET product search can select logically deleted christmas special by forcibly commenting out the remainder of where clause	test/api/search.test.ts	todos	comentario SQL devolve produto excluido
(b)	GET product search can select logically deleted unsafe product by forcibly commenting out the remainder of where clause	test/api/search.test.ts	todos	comentario SQL devolve produto excluido
(b)	GET all orders by injecting into orderId	test/api/track-result.test.ts	todos	injecao em orderId devolve todos os pedidos
(c)	GET user profile renders evaluated SSTI payload for username containing valid expression	test/api/user-profile.test.ts	todos	template avaliado (SSTI #{7*7} -> 49)
(c)	POST new user with XSS attack in email address	test/api/user.test.ts	todos	iframe javascript: gravado sem neutralizacao
(a)	infinite loop payload does not succeed but solves "rceChallenge"	test/server/b2bOrder.unit.test.ts	todos	asserção de desafio resolvido
(a)	timeout after 2 seconds solves "rceOccupyChallenge"	test/server/b2bOrder.unit.test.ts	todos	asserção de desafio resolvido
(a)	should mark challenge as solved and save it	test/server/challengeUtils.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve challenge if criteria is met and not yet solved	test/server/challengeUtils.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "easterEggLevelTwoChallenge"	test/server/easterEgg.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "directoryListingChallenge" when requesting acquisitions.md	test/server/fileServer.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "easterEggLevelOneChallenge" when requesting eastere.gg with Poison Null Byte attack	test/server/fileServer.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "forgottenDevBackupChallenge" when requesting package.json.bak with Poison Null Byte attack	test/server/fileServer.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "forgottenBackupChallenge" when requesting coupons_2013.md.bak with Poison Null Byte attack	test/server/fileServer.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "misplacedSignatureFileChallenge" when requesting suspicious_errors.yml with Poison Null Byte attack	test/server/fileServer.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "uploadSizeChallenge" when file size exceeds 100000 bytes	test/server/fileUpload.unit.test.ts	todos	asserção de desafio resolvido
(a)	should solve "uploadTypeChallenge" when file type is not PDF	test/server/fileUpload.unit.test.ts	todos	asserção de desafio resolvido
(c)	can be bypassed by exploiting lack of recursive sanitization	test/server/insecurity.unit.test.ts	todos	sanitizacao contornada: script entregue

Crit.	Teste	Arquivo	Casos	Motivo
(c)	can be bypassed to allow working HTML payload to be returned	test/server/insecurity.unit.test.ts	todos	sanitizacao legada contornada: script entregue
(a)	should solve "premiumPaywallChallenge"	test/server/premiumReward.unit.test.ts	todos	asserção de desafio resolvido
(a)	redirecting to https://blockchain.info/address/1AbKfgvw9psQ41NbLi8kufDQTezwG8DRZm should solve the "redirectCryptoCurrencyChallenge"	test/server/redirect.unit.test.ts	todos	asserção de desafio resolvido
(a)	redirecting to https://explorer.dash.org/address/Xr556RzuwX6hg5EGpkybbv5RanJoZN17kW should solve the "redirectCryptoCurrencyChallenge"	test/server/redirect.unit.test.ts	todos	asserção de desafio resolvido
(a)	redirecting to https://etherscan.io/address/0x0f933ab9fcaaa782d0279c300d73750e1311eae6 should solve the "redirectCryptoCurrencyChallenge"	test/server/redirect.unit.test.ts	todos	asserção de desafio resolvido
(a)	tricking the allowlist should solve "redirectChallenge"	test/server/redirect.unit.test.ts	todos	asserção de desafio resolvido
(a)	is solved when an authenticated user passes someone elses ID when writing feedback	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	is solved when an unauthenticated user passes someones ID when writing feedback	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"scoreBoardChallenge" is solved when the 1px.png transpixel is requested	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"adminSectionChallenge" is solved when the 19px.png transpixel is requested	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"tokenSaleChallenge" is solved when the 56px.png transpixel is requested	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"extraLanguageChallenge" is solved when the Klingon translation file is requested	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"retrieveBlueprintChallenge" is solved when the blueprint file is requested	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"missingEncodingChallenge" is solved when the crazy cat photo is requested	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"accessLogDisclosureChallenge" is solved when any server access log file is requested	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	is solved when an error occurs on a response with OK 200 status code	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	${statusCode} status code	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	is solved when the link in the O-Saft product goes to ${config.get<string>('challenges.overwriteUrlForProductTamperingChallenge')}	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"jwtUnsignedChallenge" is solved when forged unsigned token has email jwtn3d@juice-sh.op in the payload	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"jwtUnsignedChallenge" is solved when forged unsigned token has string "jwtn3d@" in the payload	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"jwtForgedChallenge" is solved when forged token HMAC-signed with public RSA-key has email rsa_lord@juice-sh.op in the payload	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(a)	"jwtForgedChallenge" is solved when forged token HMAC-signed with public RSA-key has string "rsa_lord@" in the payload	test/server/verify.unit.test.ts	todos	asserção de desafio resolvido
(e)	PUT update existing product is possible due to Missing Function-Level Access Control vulnerability	test/api/product.test.ts	todos	Altera um produto sem credencial e espera sucesso.
(e)	GET who-am-i with fields parameter can be tricked into returning password	test/api/user.test.ts	todos	Exige que a resposta traga a senha.
(e)	GET serves a directory listing	test/api/ftp-folder.test.ts	todos	Exige a página de listagem de /ftp.
(e)	GET serves a directory listing	test/api/file-serving.test.ts	todos	Exige a página de listagem de /encryptionkeys.

Crit.	Teste	Arquivo	Casos	Motivo
(e)	GET folder containing access log files for "Access Log" challenge	`test/api/file-serving.test.ts`	todos	Exige baixar o log de acesso sem credencial.
(e)	GET access log file for the current day	`test/api/logfile-server.test.ts`	todos	Exige baixar o log de acesso sem credencial.
(e)	GET error message with information leakage when calling /redirect without query parameter	`test/api/redirect.test.ts`	todos	Exige a mensagem de erro interna na resposta.
(e)	GET error message with information leakage when calling /redirect with unrecognized query parameter	`test/api/redirect.test.ts`	todos	Exige a mensagem de erro interna na resposta.
(e)	GET error message with information leakage when calling unrecognized path with /rest in it	`test/api/api.test.ts`	todos	Exige a mensagem de erro interna na resposta.
(e)	POST erasure request with non-existing file path as layout parameter throws error	`test/api/erasure-request.test.ts`	todos	Exige que o layout do cliente chegue ao sistema de arquivos.
(e)	POST sandbox breakout attack in "orderLinesData" will raise error	`test/api/b2b-order.test.ts`	todos	O erro só existe se o código enviado pelo cliente for avaliado.
(e)	POST endless loop exploit in "orderLinesData" will raise explicit error	`test/api/b2b-order.test.ts`	todos	O erro só existe se o código enviado pelo cliente for avaliado.
(e)	POST busy spinning regex attack does not raise an error	`test/api/b2b-order.test.ts`	todos	O erro só existe se o código enviado pelo cliente for avaliado.
(d)	should add an image to the gallery for each feedback with formatted comment and stars	`frontend/src/app/about/about.component.spec.ts`	746c0b	Exige a chamada de bypassSecurityTrust, que é o sink apontado pelo alerta.
(d)	should set Last-Login IP from JWT as trusted HTML	`frontend/src/app/last-login-ip/last-login-ip.component.spec.ts`	417d1d	Exige a chamada de bypassSecurityTrust, que é o sink apontado pelo alerta.
(d)	should render product descriptions as trusted HTML	`frontend/src/app/search-result/search-result.component.spec.ts`	5bc31b, ad5710	Exige a chamada de bypassSecurityTrust, que é o sink apontado pelo alerta.
(d)	should pass the search query as trusted HTML	`frontend/src/app/search-result/search-result.component.spec.ts`	5bc31b, ad5710	Exige a chamada de bypassSecurityTrust, que é o sink apontado pelo alerta.
(d)	should consider order number as trusted HTML	`frontend/src/app/track-result/track-result.component.spec.ts`	5ea334	Exige a chamada de bypassSecurityTrust, que é o sink apontado pelo alerta.
(d)	GET password change for Bender without current password using GET request	`test/api/password.test.ts`	9ea0dd	Exige trocar a senha sem informar a atual.
(d)	returns SHA-256 HMAC with "pa4qacea4VK9t9nGv7yZtwmj" as salt any input string	`test/server/insecurity.unit.test.ts`	60988b, f9cfca	Fixa o digest da chave escrita no código.
(d)	returns MD5 hash for any input string	`test/server/insecurity.unit.test.ts`	41302b	Fixa o digest MD5 que o alerta manda substituir.
(d)	GET existing basket with contained products by id	`test/api/basket.test.ts`	966898	jim (usuário 2) lê o carrinho 1, do admin, e espera sucesso.
(d)	POST placing an order for an existing basket returns orderId	`test/api/basket.test.ts`	bd16f4	jim (usuário 2) fecha o carrinho 1, do admin, e espera sucesso.
(d)	calculates and persists ${expression} = ${expected}	`tests/functional/juice_shop/captcha_arithmetic.test.ts`	4d38ad	Afirma o answer na resposta, que é o alerta.
(d)	POST sanitizes unsafe HTML from comment	`test/api/feedback.test.ts`	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
(d)	POST feedback in a non-existing users name as anonymous user fails with constraint error	`test/api/feedback.test.ts`	4d38ad, ff4689	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento. Envia rating 0: exige que a nota continue sem limite mínimo.
(d)	POST feedback can be created without actually supplying comment	`test/api/feedback.test.ts`	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
(d)	POST feedback cannot be created without actually supplying rating	`test/api/feedback.test.ts`	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
(d)	POST feedback cannot be created with wrong CAPTCHA answer	`test/api/feedback.test.ts`	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
(d)	DELETE existing feedback	`test/api/feedback.test.ts`	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
(d)	GET with an ignored scraper user agent does not solve exposedMetricsChallenge	`test/api/metrics.test.ts`	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.

Crit.	Teste	Arquivo	Casos	Motivo
(d)	GET returns 200 with text/plain content type	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes version info gauge after update loop runs	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes per-difficulty and per-category challenge solved/total gauges	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes cheat score gauge	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes coding challenge progress gauges for all three phases	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes registered user counts from update loop	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes http request counter incremented by the request middleware	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes file upload success counter after a valid upload	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	GET includes file upload error counter after an upload that triggers a downstream error	test/api/metrics.test.ts	488a4d, 8be00f	Requisição sem credencial: exige que /metrics continue público.
(d)	POST new admin	test/api/user.test.ts	2d60f2, 8655da	Exige que o cliente escolha o próprio papel no cadastro. Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	POST new deluxe user	test/api/user.test.ts	2d60f2, 8655da	Exige que o cliente escolha o próprio papel no cadastro. Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	POST new accounting user	test/api/user.test.ts	2d60f2, 8655da	Exige que o cliente escolha o próprio papel no cadastro. Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	POST new user	test/api/user.test.ts	8655da	Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	POST new blank user	test/api/user.test.ts	8655da	Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	POST same blank user in database	test/api/user.test.ts	8655da	Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	POST whitespaces user	test/api/user.test.ts	8655da	Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	POST user not belonging to customer, deluxe, accounting, admin is forbidden	test/api/user.test.ts	8655da	Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	GET password change for newly created user with recognized token as Authorization header	test/api/password.test.ts	8655da	Cadastra sem passwordRepeat: exige que a validação continue opcional.
(d)	should return 500 if QuantityModel.findOne fails during checkout	test/api/basket.test.ts	bd16f4	bjoern fecha o carrinho 4, da amy, e espera chegar à consulta de estoque.
(d)	POST feedback is associated with current user	test/api/feedback.test.ts	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
(d)	POST feedback is associated with any passed user ID	test/api/feedback.test.ts	4d38ad	Usa o answer devolvido pelo servidor para preparar o teste: exige o vazamento.
(d)	does not discount a campaign with a mismatched date	tests/functional/juice_shop/campaign_discount.test.ts	ab8d19	Exige que a data enviada pelo cliente continue decidindo o desconto.
(d)	PATCH single product review can be edited	test/api/product-review.test.ts	3d463b, 4a7e01	Token sem usuário edita a avaliação de outra pessoa e espera sucesso.
(d)	should cycle through the available carousel images when there are more feedbacks than images	frontend/src/app/about/about.component.spec.ts	746c0b	O mock só oferece bypassSecurityTrustHtml, que é o sink apontado pelo alerta.
(d)	POST with non-OK response falls back to storing URL as profile image	test/api/profile-image-upload.test.ts	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
(d)	POST with empty-body response (204) falls back to storing URL as profile image	test/api/profile-image-upload.test.ts	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
(d)	POST with valid response writes file and redirects to profile	test/api/profile-image-upload.test.ts	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
(d)	POST with PNG URL extension saves file using PNG extension	test/api/profile-image-upload.test.ts	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.

Crit.	Teste	Arquivo	Casos	Motivo
(d)	POST with unrecognised URL extension defaults to JPG extension	`test/api/profile-image-upload.test.ts`	f6324e	Baixa a imagem de localhost: exige que o servidor acesse endereços internos.
(d)	GET promotion video page contains subtitles as <script>	`test/api/promotion-video.test.ts`	593661, c03720, f50218	Exige as legendas dentro da tag script apontada pelo alerta.
(d)	should expand internal entities	`test/server/xml.unit.test.ts`	f7a5e2	Exige a expansão de entidades que o alerta manda desligar.
(d)	PUT update basket ID of basket item without basket ID	`test/api/basket-item.test.ts`	af8889, ba6a42	jim move um item para o carrinho 3, do bender, e espera sucesso.